

Threat Hunting na Prática

da hipótese à detecção, com estudos de caso no Hikari

Lourenço Alves Pereira Júnior Sidnei Barbieri Ágney Lopes Roth Ferraz

Minicurso

Time Hikari

O que você leva daqui

- Um **método**: hipótese, dados, investigação, detecção.
- Três caçadas completas, do primeiro filtro à regra derivada.
- O hábito de desconfiar do topo da tabela: em cada caso, **a consulta óbvia dá a resposta errada**.
- Um cenário para jogar no Hikari: 20 desafios, 49.277 eventos, respostas conferidas por código.

Cenário fictício, feito para este curso. Nenhum dado de competição é usado.

Por que caçar

Toda detecção é uma aposta feita no passado

A detecção

- reativa e automática
- descreve o que alguém já viu
- o adversário não é obrigado a repetir

A caça

- humana e orientada por hipótese
- procura o que a detecção não reconhece
- termina numa detecção nova

Critério de sucesso

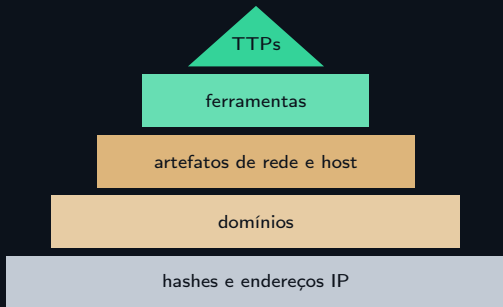
Reduzir a incerteza sobre o ambiente. “A técnica não está em curso”, com evidência, também é resultado.

O ciclo que vamos repetir três vezes



Núcleo comum aos modelos **PEAK** (Splunk) e **TaHiTI** (setor financeiro holandês).

O que caçar: comportamento, não indicador



Pirâmide da Dor (Bianco): quanto mais alto, mais caro para o adversário trocar.

ATT&CK dá o vocabulário: táticas (o objetivo) e técnicas (o como).

As três hipóteses de hoje partem de comportamento. IP, domínio e hash aparecem só como consequência.

Telemetria normalizada e o Kibana

- **ECS:** os mesmos nomes em todas as fontes. `source.ip`, `user.name`, `host.name`, `event.outcome`, `process.executable`.
- **KQL filtra:** `event.dataset:"vpn" and event.outcome:"failure"`
- **A visualização agrega:** contagem, contagem única, soma e ordenação são feitas no Lens ou no painel do campo.
- **Pivô:** o valor achado numa fonte vira filtro em outra.

Notação dos slides

`<filtro KQL>` → *agregação que responde à pergunta*

O que o volume de alertas faz com um SOC

Medição de quatro anos num SOC em operação:

- 24 mil a 134 mil alertas por dia
- 0,01% ligados a ataques verdadeiros
- investigação pós-ataque: 53 dias em média

E os falsos positivos?

Praticantes dizem que a maior parte é **disparo benigno**: alarme verdadeiro, explicado por comportamento legítimo do ambiente.

Yang et al., USENIX Security 2024; AIAhmedi et al., USENIX Security 2022.

Quem caça, e como

- Entrevistas com 22 caçadores: três abordagens combinadas (hipótese, inteligência e exploratória), e a maior dificuldade é **formular a hipótese**.
- A atividade exige **conhecimento tácito** — por isso se aprende fazendo, não lendo.
- Em equipes que caçam para órgãos federais dos EUA, onde a caça é obrigatória, **a maioria opera sem processo definido**.

Badva et al. e Maxam & Davis, USENIX Security 2024.

A pesquisa automatiza a investigação. E o caçador?

O que já existe

- grafos de proveniência reconstroem a história do ataque
- detectores em linha, resumo de grafos enormes

Por que ainda depende de gente

- custo de operação e qualidade da atribuição
- ataques de mimetismo evadem os detectores sem mudar o ataque

A consequência para hoje

Quanto mais automática a detecção, mais vale quem formula a hipótese que ela ainda não conhece.

A Aurora Telecom

O cenário

- Operadora fictícia: 120 colaboradores, 5 servidores, 2 controladores de domínio, 2 servidores de arquivos
- 3 dias, 9 a 11 de março de 2026 (horários em UTC)
- 49.277 eventos em ECS

Conjunto	Eventos
dns	22.159
firewall	9.655
fileserver	7.340
edr	4.696
vpn	2.967
auth	2.460

O ruído foi escolhido para enganar

A sonda que erra a senha da VPN, a atualização que todos consultam de hora em hora, o backup de gigabytes, o inventário que enumera grupos a cada dez minutos.

Cada resposta é recalculada por código

- Gerador determinístico: a mesma semente gera os mesmos eventos.
- Cada caso declara o que injeta e o que pergunta.
- Um conferidor **independente** refaz o caminho de cada pergunta sobre todos os eventos, ruído incluso.
- E confere as iscas: o caminho ingênuo **tem que** dar outra resposta.

```
ok  c1-origem esperado='203.0.113.77' obtido='203.0.113.77'
```

```
ok  isca de c1-origem:  a origem com mais falhas leva a outra resposta
```

```
ok  isca de c3-conta:  a conta com mais eventos de enumeração leva a outra resposta
```

Onde a prática acontece

Na plataforma

- o enunciado, o SIEM ao lado e o campo da resposta
- a dica custa pontos e é o **refinamento da hipótese**, nunca a resposta
- acertar libera a próxima fase de evidências para todos

No caderno

- notebooks/caso1..3.ipynb, com pandas
- os mesmos passos, a tabela de cada agregação
- a última célula confere a resposta contra o gabarito

Os dois caminhos usam a mesma evidência, e nenhum depende do outro.

A tela do desafio

INVESTIGAÇÃO ATUAL

A Origem Que Entrou

Abrir SIEM

Placar ao vivo

Médio

A VPN registrou milhares de falhas de autenticação no período. Informe o endereço de origem que tentou muitas contas diferentes e conseguiu estabelecer uma sessão.

Estudo de caso 1 — Da força bruta ao privilégio. Hipótese de partida: Se alguém adivinhou uma senha da VPN, a mesma origem externa acumula falhas em muitas contas diferentes e, em algum momento, uma sessão bem-sucedida.

Considere todo o período retido no SIEM: a janela narrada situa o caso, não limita a busca.

200 pontos

Enviar resposta

Use o SIEM para investigar os eventos e envie a flag quando tiver evidência suficiente.

Formato: `flag{resposta}`. Escreva sua resposta entre as chaves. Maiúsculas e minúsculas não importam.

Enviar

Quem já resolveu

0

► Desbloquear dica por 40 pontos

A superfície do SIEM

 Hikari

[Ao vivo](#) [Como participar](#) [Questionário](#) [Usuários](#) [Equipes](#) [Desafios](#)

[Notificações](#) [Equipe](#) [Perfil](#) [Configurações](#) [Sair](#)

DESAFIOS REAIS, AMEAÇAS OCULTAS

Operação SIEM

Superfície operacional de competition1. Use os sinais abaixo para priorizar a investigação e abra o Discover quando precisar pivotar em KQL.

[Abrir Discover](#) [Dashboard Kibana](#) [Ver desafios](#)

Atalhos de caça

Consultas KQL prontas, já com o período que cobre todos os registros da competição. Clique para abrir o Discover filtrado.

Severidade alta ou crítica

As linhas que o pipeline marcou como prioritárias.

Autenticação recusada

Tentativas de entrar que falharam. Bom ponto de partida.

Atividade nos endpoints

O que o agente viu nas máquinas: processos, arquivos, execuções.

Tráfego do firewall

Conexões permitidas e barradas na borda da rede.

Consultas de DNS

Nomes resolvidos. Útil para achar domínios usados por um atacante.

Portas de interesse

SSH, RDP, compartilhamento e web alternativa: movimento lateral.

Caso 1 — Da força bruta ao privilégio

Hipótese de partida

Se alguém adivinhou uma senha da VPN, a mesma origem externa acumula falhas em **muitas contas diferentes** e, em algum momento, uma sessão bem-sucedida.

T1133 External Remote Services · T1110 Brute Force · T1078 Valid Accounts · T1021.001 RDP · T1136.001 Create Local Account

Passo 1: o volume engana

`event.dataset:"vpn" and event.outcome:"failure"` → *source.ip por contagem*

Origem	Falhas	Contas distintas	Sucesso?
10.20.5.14	1.440	1	não
203.0.113.77	1.026	62	sim
177.39.199.144	2	2	sim

Isca: a sonda de monitoramento com senha vencida. Muitas falhas, uma conta, nunca entra. A pergunta certa não é “quem mais falhou”, é “**quantas contas cada origem tentou**”.

Passos 2 a 5: da conta ao novo administrador

1. `source.ip:"203.0.113.77" and event.outcome:"success"`
sessão como **c.moura** às 05:17:43, 3 s após a última falha; endereço interno `client.nat.ip`
= 10.8.200.23
2. Pivô de **endereço**, não de conta (c.moura tem logons legítimos):
`event.dataset:"auth" and source.ip:"10.8.200.23"` → logon remoto em **SRV-FIN-02**
3. `host.name:"SRV-FIN-02" and event.code:("4720" or "4732")`
conta **svc_relatorios** criada e posta em Administradores

Linha do tempo: 04:10 primeira falha · 05:17 sessão · 05:24 RDP · 05:30 conta criada · 05:31 administrador

A detecção que fica

Muitas contas falhando a partir da mesma origem, seguidas de sucesso

```
condition: falhas | count(distinct user.name) by source.ip > 15 within 1h  
          followed by sucesso from the same source.ip within 1h  
falsepositives: NAT compartilhado com poucos usuários
```

- Não cita 203.0.113.77: o adversário troca de IP em minutos.
- Segunda regra, menos ruidosa: conta criada e adicionada a grupo administrativo pela mesma conta, em minutos.

Prática 1 — a origem que entrou

O que fazer (25 min)

1. Abra o desafio *A Origem Que Entrou* e o SIEM ao lado.
2. Comece pela contagem de falhas por origem. Anote o que achou.
3. Troque a pergunta: quantas **contas diferentes** por origem, entre as que entraram?
4. Siga até a conta que cedeu e o minuto zero.

Equivalente em caderno: `notebooks/caso1.ipynb`.

O que observar

Quase todo mundo encontra primeiro a sonda de monitoramento. Guarde o momento em que a pergunta mudou: é ele que se leva para o trabalho.

Caso 2 — O canal que respira

Hipótese

Hipótese de partida

Um implante que pede ordens a um servidor externo gera consultas **regulares** a um domínio que **quase ninguém mais** na empresa consulta.

T1071.001 Web Protocols · T1036.005 Match Legitimate Name · T1204.002 Malicious File ·
T1041 / T1048 Exfiltration

Frequência com raridade

`event.dataset:"dns"` → *dns.question.name: contagem e contagem única de host.name*

Domínio	Consultas	Estações
update.aurora.com.br	8.640	120
api.whatsapp.com	1.109	120
telemetria-aurora-cdn.net	719	1
fornecedor-cabos.com.br	3	1

Na estação WKS-ENG-117: intervalos de **285 a 315 s**, mediana 300, por três dias, madrugadas incluídas.

A atualização legítima, na mesma estação: de 372 a 6.951 s.

O nome emprestado

```
host.name:"WKS-ENG-117" and process.name:"OneDriveUpdater.exe"
```

360 execuções legítimas

- C:\Program Files\Microsoft OneDrive\
- pai: OneDrive.exe
- mesmo hash em todas as estações

1 execução

- C:\Users\r.lemos\AppData\Roaming\
- pai: WINWORD.EXE
- outro hash

O Word abriu Reajuste_Contratos_2026.docm. O nome engana; caminho, hash e pai não.

A exfiltração que só aparece somando

Isca 1: o maior fluxo isolado, 8,8 GB, é o backup para 10.30.0.10, **interno**.

Isca 2: somar `destination.bytes` aponta o espelho de atualização, 22,7 GB de **download**.

`not destination.ip:"10.0.0.0/8"` → *soma de `source.bytes` por destino*

198.51.100.61: 2.292.933.770 bytes enviados
180 fluxos de 11 a 14,5 MB
de 01:05 a 02:37 de 10/03

Lição

Nenhum fluxo passaria de um limiar de alerta. A soma, na direção certa, é inequívoca.

Prática 2 — o canal que respira

O que fazer (25 min)

1. Em duplas: uma pessoa persegue o domínio, a outra o volume que sai.
2. Domínio: contagem e contagem única de estações por nome consultado.
3. Volume: soma de bytes enviados por destino externo, e não o maior fluxo.
4. Encontrem-se na mesma estação e nomeiem o processo.

Equivalente em caderno: `notebooks/caso2.ipynb`.

O que observar

As duas iscas ensinam a mesma lição: a pergunta certa quase nunca é *qual é o maior*.

Caso 3 — Do mapa do diretório ao impacto

Hipótese de partida

Antes de cifrar, quem invade um domínio enumera **muitos grupos em pouco tempo**, fora da rotina de inventário, e o movimento lateral vem logo depois.

T1069.002 Domain Groups · T1569.002 Service Execution · T1490 Inhibit System Recovery ·
T1486 Data Encrypted for Impact

Amplitude, não volume

```
event.dataset:"auth" and event.code:"4799"
```

Conta	Eventos 4799	Grupos distintos
svc_inventario	1.296	3
adm.backup	61	47

Isca: o inventário confere os mesmos 3 grupos a cada dez minutos.

adm.backup: Domain Admins, Backup Operators, Aurora-Servidores-Arquivos... em **6 minutos**, contra o DC01.

Pivô: `host.ip:"10.40.0.140" and winlog.logon.type:"2"` → **WKS-ADM-104**

Do mapa à cifra em 25 minutos

UTC, 10/03	Evento
16:40–16:46	enumeração: 61 consultas, 47 grupos
17:05:00	logon de rede no FS01
17:05:09	serviço PSEXESVC instalado
17:05:14	aurora_upd.exe em C:\Windows\Temp
17:05:31	vssadmin delete shadows /all /quiet
17:05:45	primeiro arquivo .aurora-lock
17:14	mesma sequência no FS02
17:30:42	último arquivo: 3.420 renomeados (2.140 + 1.280)

Isca: o agente de backup renomeia 518 a 615 arquivos por noite. Separe pela **extensão nova**.

A detecção que teria dado tempo

Enumeração ampla fora do inventário

```
condition: event.code: 4799 and not user.name: svc_inventario  
          | count(distinct group.name) by user.name > 20 within 15m
```

Cópias de sombra apagadas

```
process.command_line|contains|all: [vssadmin, delete, shadows]  
level: critical
```

A caçada chegou tarde. As regras miram o **começo da cadeia**, e não o fim.

Prática 3 — do mapa do diretório ao impacto

O que fazer (20 min)

1. Parta do alerta: arquivos renomeados nos servidores de arquivos.
2. Volte no tempo: quem enumerou muitos grupos diferentes, e de onde.
3. Reconstrua a sequência até a cifra e meça a janela que havia para agir.
4. Escreva a regra derivada, com o limiar e o falso positivo esperado.

O que observar

A enumeração antecede a cifra em 25 minutos. É essa janela que justifica caçar antes do alerta.

Equivalente em caderno: `notebooks/caso3.ipynb`.

Fechamento

Conduzir um exercício: antes

1. **Recalcular todas as respostas** sobre a evidência, e não conferir o gabarito contra a flag cadastrada.
2. **Conferir cada dica:** ela precisa levar ao campo que contém a resposta.
3. **Conferir a estabilidade:** a resposta não pode mudar quando a próxima fase entra no índice.
4. **Conferir as iscas:** a consulta ingênua precisa continuar levando a outra resposta.
5. **Ensaia com gente** que não fez a curadoria.

Cada item existe porque a falta dele já custou caro em alguma edição.

Conduzir um exercício: durante e depois

Durante

- fases caem por mérito, uma vez, para todos
- placar com um só critério de desempate, dito na tela
- relógio público; pausar e estender a um clique

Depois

- solução comentada em cada desafio
- questionário curto, ainda na tela
- certificado nominal com código de verificação

Um cuidado que parece detalhe

Nenhum destaque deve premiar tentativa e erro: isso incentiva adivinhar a flag e estraga qualquer medida que use o número de tentativas.

O que os três casos têm em comum

1. A hipótese era sobre **comportamento**.
2. A primeira agregação era a **errada**, e isso era esperado: a pergunta mudou de “quanto” para “quantos diferentes”, “com que regularidade”, “em que direção”.
3. Cada passo foi um **pivô** no valor que só o ataque produz.
4. A caçada terminou numa **regra**, com o falso positivo declarado.

- 20 desafios em três trilhas, na ordem dos pivôs
- dica com custo = o refinamento de hipótese
- solução comentada depois do encerramento
- pacote gerado pelo mesmo conferidor do capítulo

Limites

Cenário sintético e limpo. Ambientes reais têm mais ruído, campos ausentes e relógios fora de sincronia. As regras ilustram a lógica; produção exige ajuste.

Agora escreva as hipóteses do seu ambiente.